You should therefore not use ID tokens for access to an API except in the narrow case of access by trusted first-party clients where you've hardened the OIDC flow appropriately based on the recommendations in the last section.

> **PRINCIPLE** Never use ID tokens for access control for third-party clients. Use access tokens for access, ID tokens for identity.

Because you shouldn't use an ID token to allow access to an API, you may need to look up identity information about a user while processing an API request or need to enforce specific authentication requirements. For example, an API for initiating financial transactions may want assurance that the user has been freshly authenticated using a strong authentication mechanism. Although this information can be returned from a token introspection request, this is not always supported by all authorization server software. OIDC ID tokens provide a standard token format to verify these requirements. In this case you may want to let the client pass in a signed ID token that it has obtained from a trusted OP. When this is allowed, the API should accept only the ID token in addition to a normal access token and make all access control decisions based on the access token.

When the API needs to access claims in the ID token, it should first verify that it's from a trusted OP by validating the signature and issuer claims. It should also ensure that the subject of the ID token exactly matches the resource owner of the access token. Ideally, the API should then ensure that its own identifier is in the audience of the ID token and that the client's identifier is the authorized party